contents

Front matter

foreword

preface

acknowledgments

about this book

about the author

about the cover illustration

Part 1. Say hello to Spring Security

1 Security today

1.1 Discovering Spring Security

1.2 What is software security?

1.3 Why is security important?

1.4 What will you learn in this book?

2 Hello, Spring Security

2.1 Starting your first project

2.2 The big picture of Spring Security class design

2.3 Overriding default configurations

Customizing user details management

Applying authorization at the endpoint level

Configuring in different ways

Defining custom authentication logic

Using multiple configuration classes

Part 2. Configuring authentication

3 Managing users

3.1 Implementing authentication in Spring Security

3.2 Describing the user

Describing users with the UserDetails contract

Detailing on the GrantedAuthority contract

Writing a minimal implementation of UserDetails

Using a builder to create instances of the UserDetails type

Combining multiple responsibilities related to the user

3.3 Instructing Spring Security on how to manage users

Understanding the UserDetailsService contract

Implementing the UserDetailsService contract

Implementing the UserDetailsManager contract

4 Managing passwords

4.1 Using password encoders

The PasswordEncoder contract

Implementing your PasswordEncoder

Choosing from the provided PasswordEncoder implementations

Multiple encoding strategies with DelegatingPasswordEncoder

4.2 Taking advantage of the Spring Security Crypto module

Using key generators

Encrypting and decrypting secrets using encryptors

5 A web app's security begins with filters

5.1 Implementing filters in the Spring Security architecture

5.2 Adding a filter before an existing one in the chain

5.3 Adding a filter after an existing one in the chain

5.4 Adding a filter at the location of another in the chain

5.5 Filter implementations provided by Spring Security

6 Implementing authentications

6.1 Understanding the AuthenticationProvider

Representing the request during authentication

Implementing custom authentication logic

Applying custom authentication logic

6.2 Using the SecurityContext

Using a holding strategy for the security context

Using a holding strategy for asynchronous calls

Using a holding strategy for standalone applications

Forwarding the security context with DelegatingSecurityContextRunnable

Forwarding the security context with DelegatingSecurityContextExecutorService

6.3 Understanding HTTP Basic and form-based login authentications

Using and configuring HTTP Basic

Implementing authentication with form-based login

Part 3. Configuring authorization

7 Configuring endpoint-level authorization: Restricting access

7.1 Restricting access based on authorities and roles

Restricting access for all endpoints based on user authorities

Restricting access for all endpoints based on user roles

Restricting access to all endpoints

8 Configuring endpoint-level authorization: Applying restrictions

8.1 Using the requestMatchers() method to select endpoints

8.2 Selecting requests to apply authorization restrictions

8.3 Using regular expressions with request matchers

9 Configuring CSRF protection

9.1 How CSRF protection works in Spring Security

9.2 Using CSRF protection in practical scenarios

9.3 Customizing CSRF protection

10 Configuring CORS

10.1 How does CORS work?

10.2 Applying CORS policies with the @CrossOrigin annotation

10.3 Applying CORS using a CorsConfigurer

11 Implementing authorization at the method level

11.1 Enabling method security

Understanding call authorization

Enabling method security in your project

11.2 Applying preauthorization rules

11.3 Applying postauthorization rules

11.4 Implementing permissions for methods

12 Implementing filtering at the method level

12.1 Applying prefiltering for method authorization

12.2 Applying postfiltering for method authorization

12.3 Using filtering in Spring Data repositories

Part 4. Implementing OAuth 2 and OpenID Connect

13 What are OAuth 2 and OpenID Connect?

13.1 The big picture of OAuth 2 and OpenID Connect

13.2 Using various token implementations

Using opaque tokens

Using non-opaque tokens

13.3 Obtaining tokens through various grant types

Getting a token using the authorization code grant type

Applying PKCE protection to the authorization code grant type

Getting a token with the client credentials grant type

Using refresh tokens to get new access tokens

13.4 What OpenID Connect brings to OAuth 2

13.5 The sins of OAuth 2

14 Implementing an OAuth 2 authorization server

14.1 Implementing basic authentication using JSON web tokens

14.2 Running the authorization code grant type

14.3 Running the client credentials grant type

14.4 Using opaque tokens and introspection

14.5 Revoking tokens

15 Implementing an OAuth 2 resource server

15.1 Configuring JWT validation

15.2 Using customized JWTs

15.3 Configuring token validation through introspection

15.4 Implementing multitenant systems

16 Implementing an OAuth 2 client

16.1 Implementing OAuth 2 login

Implementing authentication with a common provider

Giving the user more possibilities

Using a custom authorization server

Adding flexibility to your configurations

Managing authorization for an OAuth 2 login

16.2 Implementing an OAuth 2 client

Part 5. Going reactive

17 Implementing security in reactive applications

17.1 What are reactive apps?

17.2 User management in reactive apps

17.3 Configuring authorization rules in reactive apps

Applying authorization at the endpoint layer in reactive apps

Using method security in reactive apps

17.4 Creating a reactive OAuth 2 resource server

Part 6. Testing security configurations

18 Testing security configurations

18.1 Using mock users for tests

18.2 Testing with users from a UserDetailsService

18.3 Using custom Authentication objects for testing

18.4 Testing method security

18.5 Testing authentication

18.6 Testing CSRF configurations

18.7 Testing CORS configurations

18.8 Testing reactive Spring Security implementations

Appendix A. Links to official documentation

Appendix B. Further reading

index

Previous chapter
< Copyright

Next chapter
front matter >